

Alias Equals Zone? Large-Scale and Stealthy Takeover of Domain Hosting Service via CNAME-Following Cross-Domain Verification

Ruixuan Li¹, Xingyu Zhao², Yunyi Zhang¹, Baojun Liu¹, Jun Shao²



清華大學
Tsinghua University



浙江工商大學
ZHEJIANG GONGSHANG UNIVERSITY

A novel domain takeover attack (AliasLeap)

Attack Goal: Take over the email and website hosting services of victim domains.

Attacker Ability: No need to control any DNS records, deploy any servers, perform any illegal operations.

Attack Harm: Deploy phishing websites, send forged emails, obtain valid certificates, theft of user privacy, hijacking account, etc.

Threats have been lurking in the domain name system for decades

Definition and common uses of CNAME records

The core role of a CNAME is to map one domain to another during DNS resolution

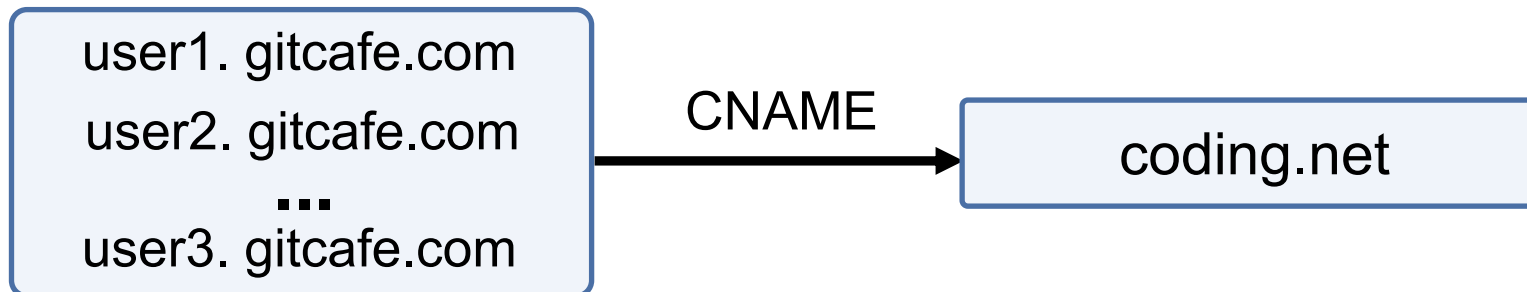
**Website
guidance**



**Brand
change**



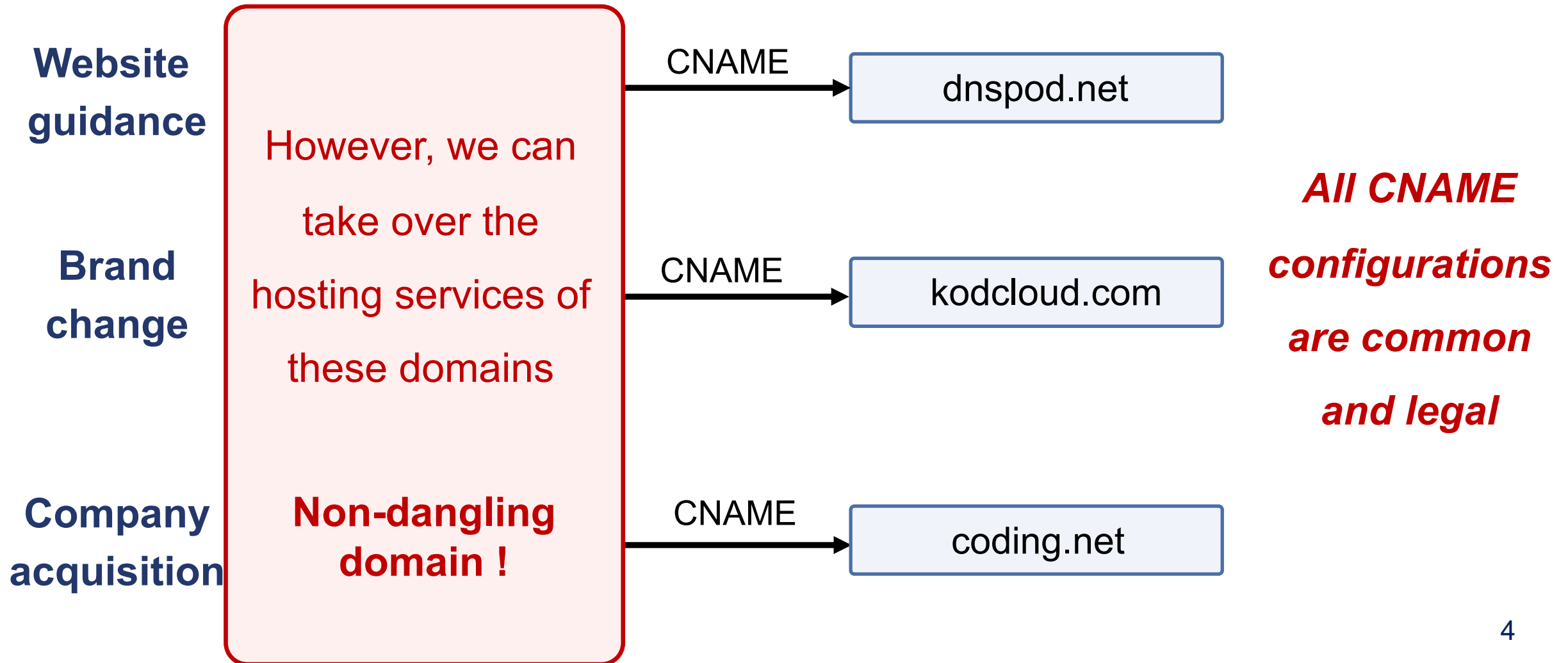
**Company
acquisition**



***All CNAME
configurations
are common
and legal***

Definition and common uses of CNAME records

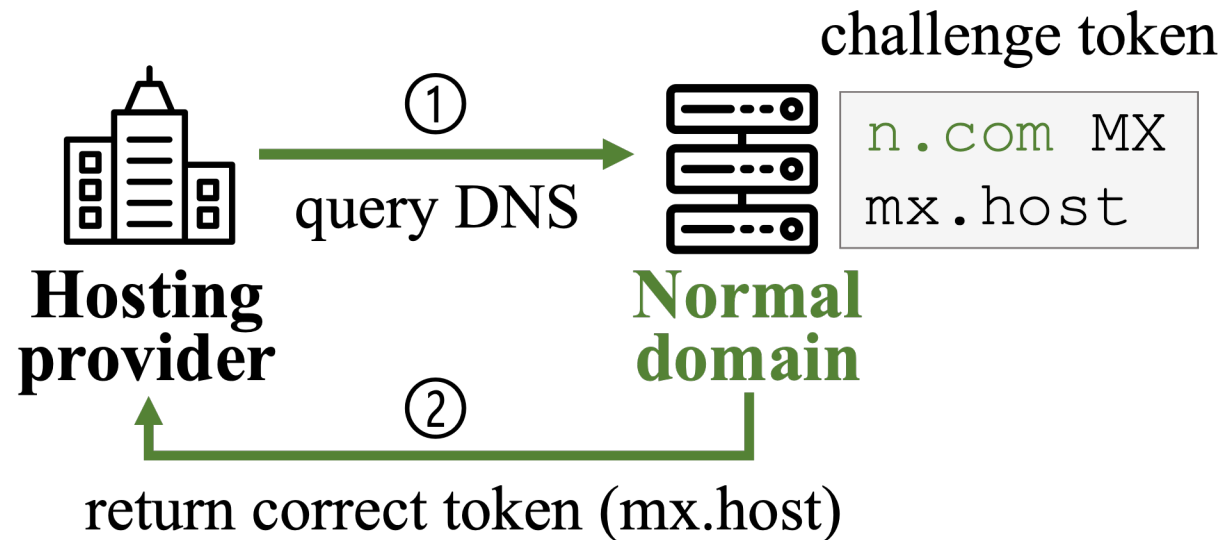
The core role of a CNAME is to map one domain to another during DNS resolution



Domain ownership verification (DOV)

The provider requires the customer to configure specified DNS records for the domain

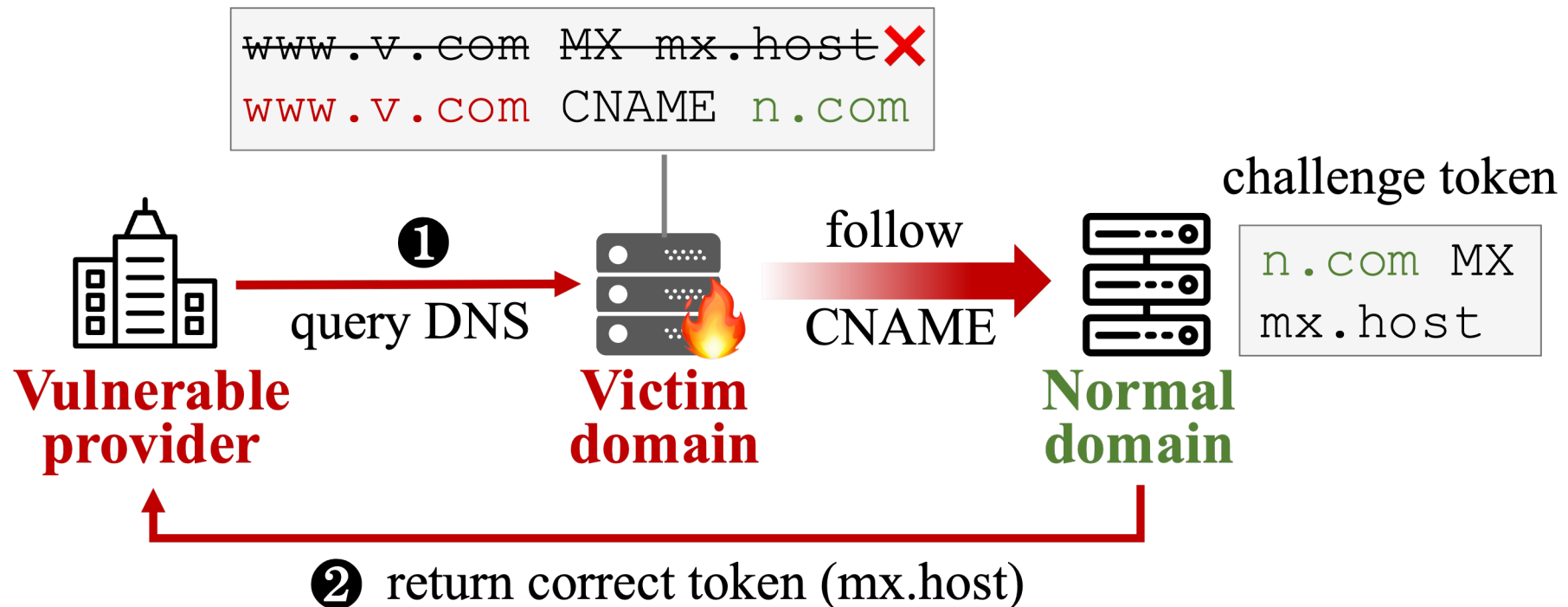
Normal DOV Logic



Common misunderstanding of CNAME capability

During the DOV process, many provider follows the CNAME record to cross-domain verify the DNS record

Vulnerable DOV Logic



The real-world impact of the attack

14 popular domain service hosting providers are affected



More than **2 million** domains can be taken over, 19819 domains at risk for longer than **10 years**



Thanks for Listening!

Ruixuan Li

Email: *lirx25@mails.tsinghua.edu.cn*

Website: *<https://ruixuanli.com/>*



清華大學
Tsinghua University



浙江工商大學
ZHEJIANG GONGSHANG UNIVERSITY